



VULNERABILITY ASSESSMENT REPORT

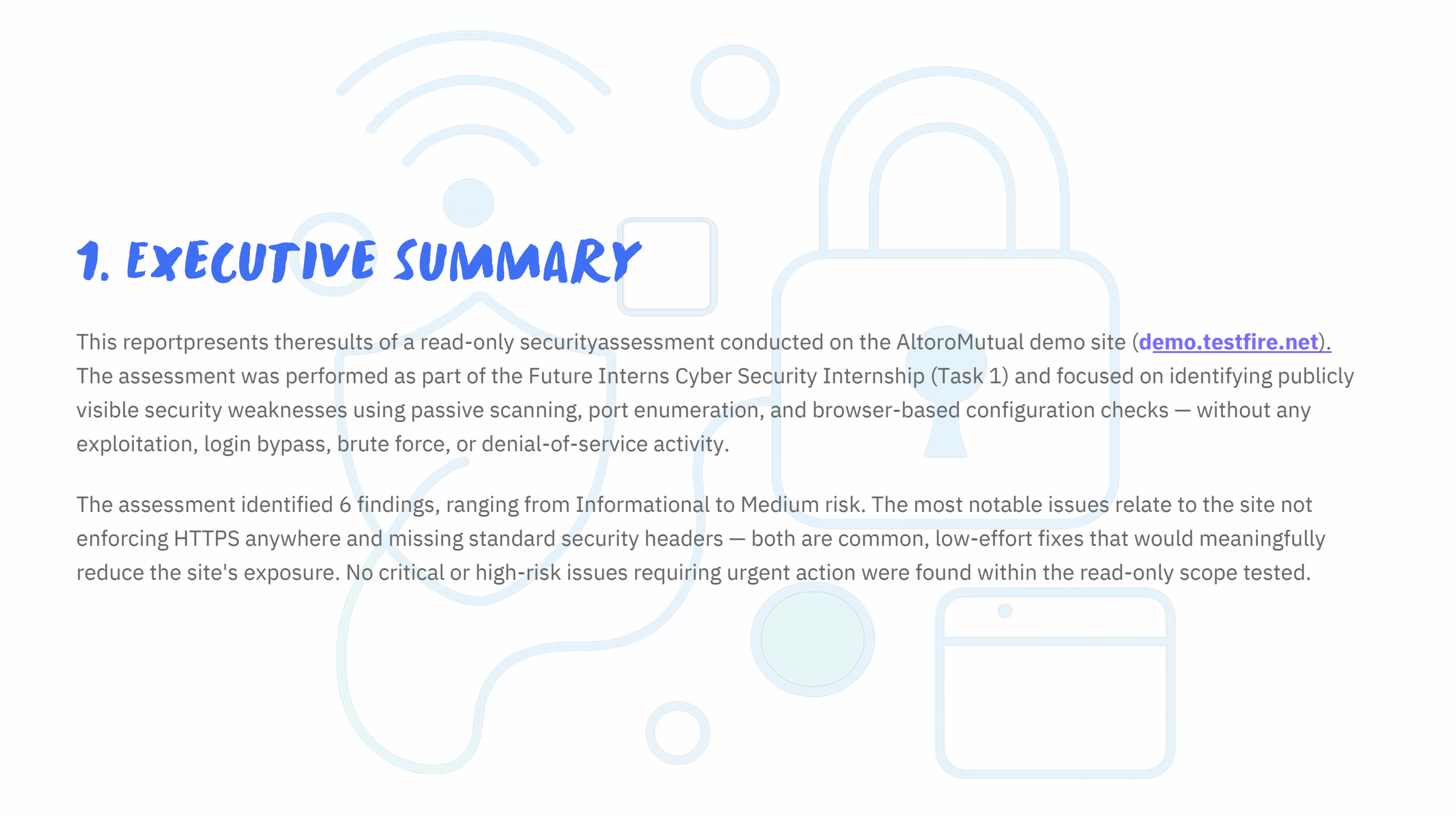
Website Assessed: <http://demo.testfire.net> (AltoroMutual—publicdemo/testbanking application)

Prepared by: Kabiraj Chapagain

Role: Cyber Security Intern — Future Interns

Repository: FUTURE_CS_01

Date: 22 September 2026



1. EXECUTIVE SUMMARY

This report presents the results of a read-only security assessment conducted on the AltoroMutual demo site (demo.testfire.net). The assessment was performed as part of the Future Interns Cyber Security Internship (Task 1) and focused on identifying publicly visible security weaknesses using passive scanning, port enumeration, and browser-based configuration checks — without any exploitation, login bypass, brute force, or denial-of-service activity.

The assessment identified 6 findings, ranging from Informational to Medium risk. The most notable issues relate to the site not enforcing HTTPS anywhere and missing standard security headers — both are common, low-effort fixes that would meaningfully reduce the site's exposure. No critical or high-risk issues requiring urgent action were found within the read-only scope tested.

2. SCOPE & METHODOLOGY

IN SCOPE:

- Public-facing pages only
- Passive scanning only
- Non-intrusive port/service enumeration
- HTTP headers and cookies review

OUT OF SCOPE (PER INTERNSHIP GUIDELINES):

- Login bypass
- Active exploitation
- Brute force attacks
- DoS testing

TOOLS USED:

Tool	Purpose
Nmap (Quick scan)	Port & service enumeration
OWASP ZAP (Passive Scan, Manual Explore)	Observed traffic only; no active attacks
Browser DevTools	Reviewed response headers and cookie settings

Methodology evidence: evidence/zap/02_zap_passive_scan_config.png — ZAP Passive Scan Rules set to Low threshold for a thorough, non-intrusive pass over captured traffic.

3. FINDINGS SUMMARY

#	Finding	Risk Level
1	No HTTPS enforcement	Medium
2	Missing security headers	Medium
3	Insecure cookie configuration (missing Secure flag)	Medium
4	Server version disclosure (Apache-Coyote/1.1)	Low
5	Unnecessary exposed service on port 8080	Low
6	Session-related response observed (ZAP)	Informational

FINDING 4.1

RISK: MEDIUM

NO HTTPS ENFORCEMENT

WHAT WE FOUND:

The site remains on plain HTTP throughout normal browsing; there is no redirect to HTTPS. The browser flags the connection as "Not Secure."

WHY IT MATTERS:

Any data submitted on the site including login credentials on the Sign In page would travel unencrypted and could be intercepted on a shared or public network.

EVIDENCE:

evidence/devtools/04_no_https_not_secure.png,
evidence/devtools/05_no_https_fullpage_view.png

RECOMMENDATION:

Enforce HTTPS site-wide with a redirect from HTTP, and enable HSTS.

FINDING 4.2

RISK: MEDIUM

MISSING SECURITY HEADERS

WHAT WE FOUND:

The server's response headers include only Content-Length, Content-Type, Date, and Server. None of the standard protective headers are present - no Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, or Strict-Transport-Security.

WHY IT MATTERS:

Without these headers, the site is more exposed to clickjacking, content-type sniffing attacks, and content injection.

EVIDENCE:

evidence/devtools/06_missing_headers_server_disclosure.png

RECOMMENDATION:

Configure the web server to send these headers on every response.

FINDING 4.3

RISK: MEDIUM

INSECURE COOKIE CONFIGURATION

WHAT WE FOUND:

The JSESSIONID session cookie has HttpOnly: true (good) but Secure: false. Combined with the lack of HTTPS enforcement (4.1), this cookie could be transmitted in plaintext.

WHY IT MATTERS:

A session cookie sent without the Secure flag can be exposed over an insecure connection, potentially allowing session hijacking.

EVIDENCE:

evidence/devtools/08_insecure_cookie_flags.png,
evidence/devtools/07_cookie_raw_value.png

RECOMMENDATION:

Enable HTTPS site-wide and set the Secure flag on all session cookies.

FINDING 4.4

RISK: LOW

SERVER VERSION DISCLOSURE

WHAT WE FOUND:

The response header Server: Apache-Coyote/1.1 reveals the exact web server/connector technology and version in use.

WHY IT MATTERS:

Publicly known version numbers make it easier for an attacker to look up known vulnerabilities matching that specific version.

EVIDENCE:

evidence/devtools/06_missing_headers_server_disclosure.png

RECOMMENDATION:

Suppress or generalize the Server header; keep underlying software patched and up to date.

FINDING 4.5

RISK: LOW

UNNECESSARY EXPOSED SERVICE (PORT 8080)

WHAT WE FOUND:

An Nmap scan showed three open ports: 80 (http), 443 (https), and 8080 (http-proxy). Port 8443 (https-alt) was confirmed closed.

WHY IT MATTERS:

A second web-facing service on a non-standard port increases the site's attack surface if it isn't intended to be publicly reachable.

EVIDENCE:

evidence/nmap/01_nmap_scan_output.png (also see nmap_scan.txt)

RECOMMENDATION:

Restrict port 8080 to internal access only unless it is required to be public, or close it if unused.

FINDING 4.6

RISK: INFORMATIONAL

SESSION-RELATED RESPONSE OBSERVED

WHAT WE FOUND:

ZAP's passive scan flagged a "Session Management Response Identified" alert on the homepage request.

WHY IT MATTERS:

This is not a vulnerability on its own — it simply confirms the application manages sessions via cookies, which is expected. It's noted here for completeness alongside the cookie finding above.

EVIDENCE:

evidence/zap/03_zap_session_management_alert.png

RECOMMENDATION:

No action needed beyond the cookie/HTTPS fixes already listed.

CONCLUSION & RECOMMENDATIONS

The Altoro Mutual demo site shows a set of configuration-level issues typical of many small business and legacy web applications. None indicate active compromise, but addressing the Medium-risk items first would meaningfully reduce the site's attack surface.

PRIORITY ORDER:

01

**ENFORCE HTTPS SITE-WIDE +
ENABLE HSTS**

02

ADD MISSING SECURITY HEADERS

03

SET SECURE FLAG ON SESSION COOKIES

04

FIXES 4.1 AND REDUCES RISK OF 4.3

05

SUPPRESS SERVER VERSION BANNER

06

REVIEW NECESSITY OF PORT 8080 EXPOSURE

6. DISCLAIMER

This assessment was conducted for educational purposes as part of the Future Interns Cyber Security Internship. It was strictly limited to passive, read-only techniques against a publicly accessible test target. No exploitation, unauthorized access, or disruption of service was performed or attempted.